

Lab 2 – Scanning and Enumeration

Scanning is the second phase in the information-gathering process. It involves actively probing the target network or system to discover open ports, services, and vulnerabilities. The goal is to identify potential entry points for exploitation.

Enumeration is a more focused phase that occurs after scanning. It involves actively querying the identified services and systems to gather specific information about them, such as user accounts, shares, resources, or configurations.

In summary, reconnaissance is the broad phase of gathering information about the target, while scanning involves actively identifying open ports and services. Enumeration is a more detailed process of querying these services and systems for specific information. These three phases are often part of a structured approach to understanding a target's environment, vulnerabilities, and potential attack vectors in cybersecurity or penetration testing scenarios.

2 IP addresses: You have permission to conduct Ethical Hacking.

- your own IP address as Defender
- an IP address assigned to your group as Attacker

Scanning Techniques

1. Determining if the system is alive:
 - *Probing sweeps* -
 - Ping sweeps (ICMP ECHO and NON-ECHO requests)
 - TCP and UDP Sweeps
2. Determining which ports are open / closed / filtered:
 - *Basic Port Scanning*
 - *Advanced Port Scanning*
3. Detecting reachable systems:
 - *Route Tracing*
 - *APT – advance worms*

Exercise 1: PING (Packet Internet Groper)

Using PING, attackers can send an Internet Control Message Protocol (ICMP) echo request to a range of addresses to determine which systems are “up and running”.

(1) ping

```
(kali㉿kali)-[~]  
└─$ ping ip address
```

What information can you find?

(2) Fping (fping allows you to ping multiple hosts)

```
(kali㉿kali)-[~]  
└─$ fping ip address1, ip address2, ip address3
```

(3) In Kali: for i in {100..180}; do ping -c1 -w1 x.y.z.\$i | grep "64 bytes"; done

(4) In cmd: for /L %i in (100, 1, 180) do @ping -n 1 x.y.z.%i | find "bytes=32"

Exercise 2: nmap

Nmap (Network Mapper) is a free and open-source network scanner.

Please do not use nmap for full port range or full IP addresses scanning to avoid being blocked since the EC2 instance is in AWS. Please use nmap to scan the certain port range: nmap -p <port range> IP address

If you can use other command instead of nmap, it would be preferred.

- (1) nmap -p <port range> IP address
- (2) nmap -sn IP address
-sn: Ping Sweep is only used to find out whether the target is alive.
- (3) nmap -PP ip address
-PP: Sweep using ICMP Non-Echo (timestamp) includes port scan.
- (4) nmap -PE ip address
-PE: ICMP Echo Request with port scan.

Exercise 3: dnsmap

DNS Network Mapper – scan domain and provide list of subdomains

dnsmap singaporetech.edu.sg

Exercise 4: TCP Sweeps and Port Scanning

For your knowledge

- (1) TCP SYN Scan (connect scan)
nmap -sT IP address
- (2) TCP SYN scan
Nmap -sS IP address
- (3) TCP FIN Scan – Stealth Scan

Exercise 5: UDP Sweeps

Nmap -sU IP address

Exercise 7: Decoy Scan

nmap -sX -D (experiment and observe in the lab; X can be S or T etc.)

nmap -sX -D [decoy1,decoy2,...] [target]

nmap -sX -D 192.168.1.10,192.168.1.11 172.35.10.200

Exercise 8: Route Tracing

- Linux and Unix Oss – **tracert**
 - tracert singaporetech.edu.sg
 - tracert -T singaporetech.edu.sg (tracert -T to use TCP rather than ICMP).
- Windows (DOS Command) – **tracert**
 - tracert singaporetech.edu.sg

Exercise 9: Enumeration

Port-based enumeration (in-depth scanning):

Determine OS and Services

Reference <http://cve.mitre.org>

Enumeration extracts information about:

Shared resources (or shares) on the network

User account information (rarely, user authentication)

Enumeration is more intrusive:

Gathered by queries via active connections to target system
Enumeration Tools:
NBTScanner, NBTScan, Net View, Reaper, nmap, netcat etc.

Banner

- nmap -sV -v --script banner IP address
 - -sV: Probes open ports to determine service/version info
 - -v: Increase verbosity
 - --script banner: Run banner grabbing script
- nmap -sS -sV -p80 -v -n -Pn --script banner sutd.edu.sg

Exercise 10: Directory or file discovery methods

Gobuster is a powerful open-source tool designed for directory and DNS brute-forcing, widely used in ethical hacking and penetration testing. Using Gobuster is legal as long as you have explicit permission from the target site's owner; doing so without permission is illegal and may violate laws like the Computer Fraud and Abuse Act (CFAA).

DirBuster is an OWASP-backed security tool that uncovers hidden directories and files on web servers. DirBuster is legal when used with the explicit permission of the website owner for ethical hacking and penetration testing purposes. Unauthorized use is illegal.

For the 2 IP addresses given to you (e.g., 18.219.250.106), you have the permission to practice Gobuster and DirBuster.

```
gobuster dir -u http://18.219.250.106/ -w /usr/share/wordlists/dirb/common.txt
```

```
(kali㉿kali)-[~]
```

```
$ gobuster dir -u http://18.219.250.106/ -w /usr/share/wordlists/dirb/common.txt
```

```
(kali㉿kali)-[~]
$ gobuster dir -u http://18.219.250.106/ -w /usr/share/wordlists/dirb/common.txt

Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

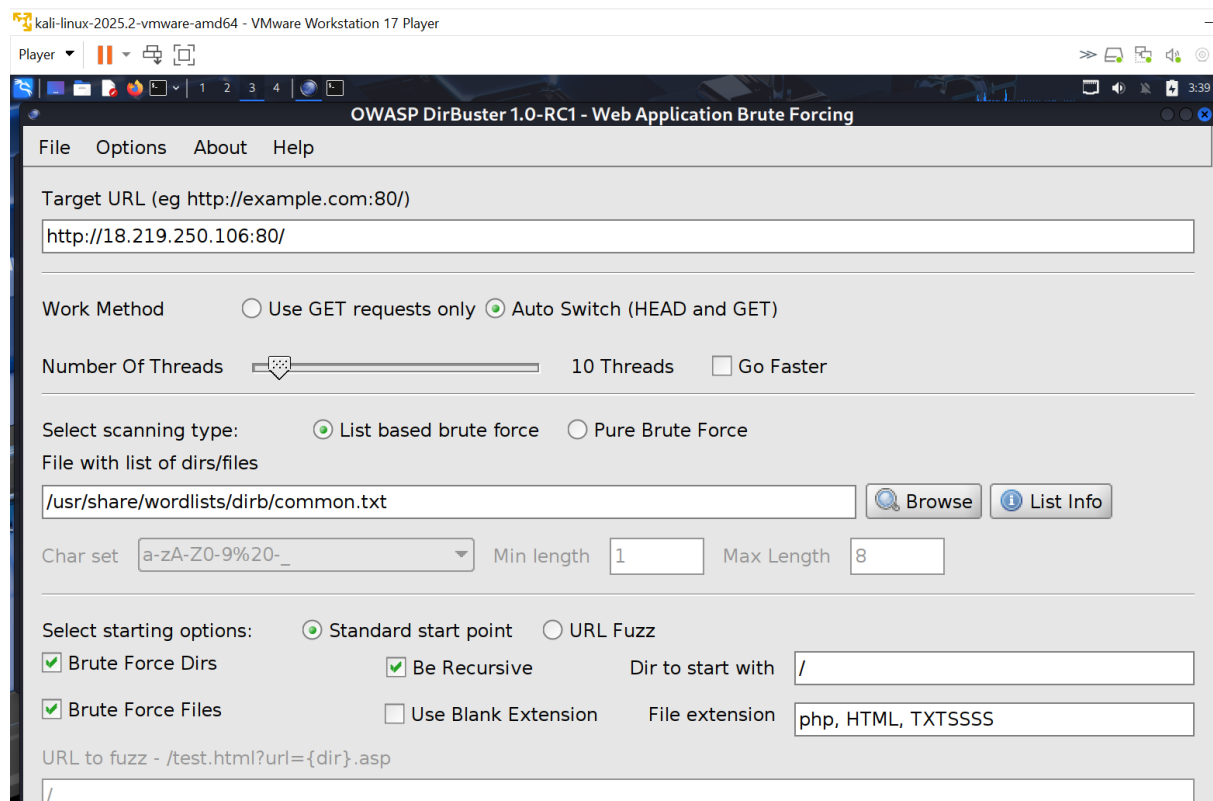
[+] Url: http://18.219.250.106/
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.6
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

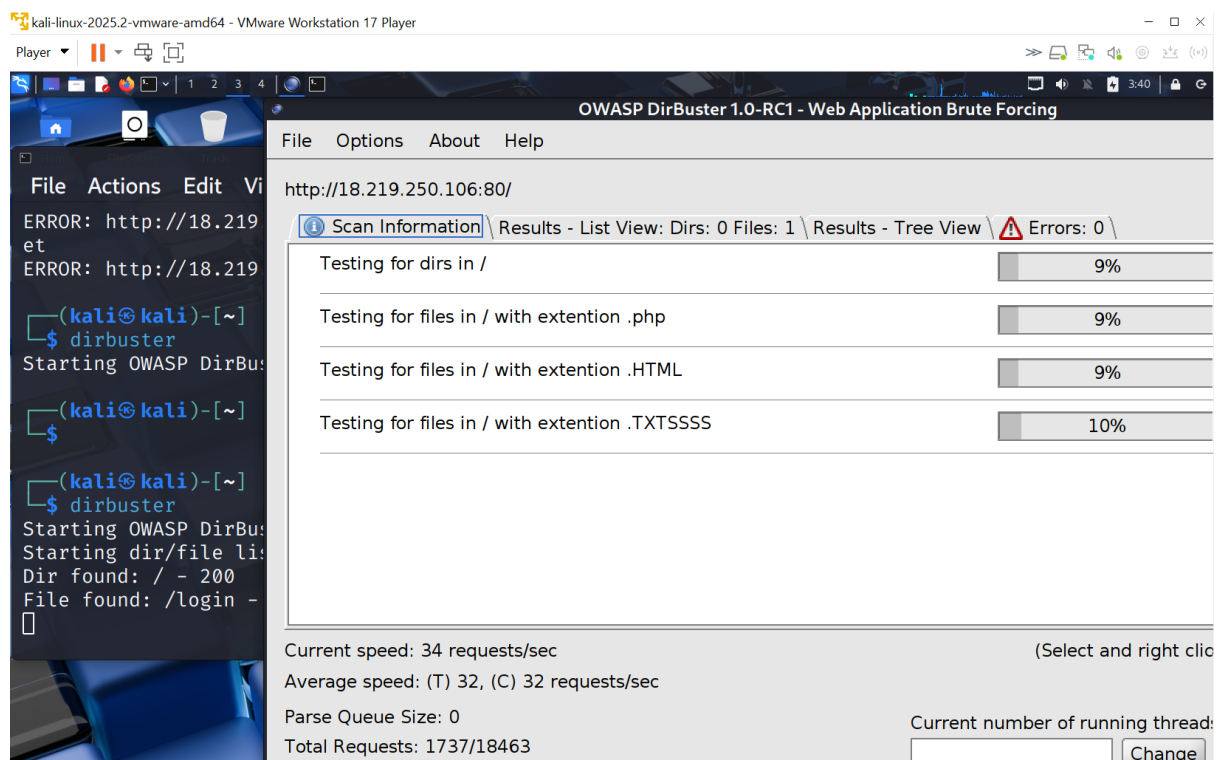
/chat (Status: 401) [Size: 36]
/dev (Status: 401) [Size: 190]
/internal (Status: 403) [Size: 166]
/legacy (Status: 503) [Size: 160]
/login (Status: 200) [Size: 3132]
/logout (Status: 302) [Size: 199] [→ /login]
/maintenance (Status: 503) [Size: 185]
/readme (Status: 401) [Size: 36]
/robots.txt (Status: 200) [Size: 38]
/system (Status: 401) [Size: 166]
Progress: 4614 / 4615 (99.98%)

Finished
```

```
(kali@kali)-[~]  
$ dirbuster  
Starting OWASP DirBuster 1.0-RC1
```



Click Start



<https://www.webasha.com/blog/discover-hidden-web-paths-how-to-use-dirbuster-for-security-assessments>